

Halden Distribution Ltd. — Active Directory findings register

Project: P3 AD Security Assessment and Privileged Access Hardening **Owner:** Muhammad Ibrahim Akmal, IT (Systems) · **Reviewed with:** Managing Director and department heads **Scoring:** Likelihood (1–5) × Impact (1–5) = risk score (1–25); priority P0–P3 from `configs/p03-remediation-priority-rules.json` · **Schema:** `configs/p03-findings-register-schema.csv`

Status: no findings recorded yet — the assessment has not been run. The table below is deliberately empty. It is filled in from the normalised output of PingCastle, Purple Knight and BloodHound CE after the assessment runs in the isolated lab, scored by `scripts/04-New-FindingsRegister.py`, and reviewed by hand before it is issued. Nothing here is pre-filled with a plausible-looking finding (AGENTS.md rule R2).

Register

ID	Finding	Tool	Category	L	I	Score	Priority	Owner	Target date	Status	Evidence
	<i>to be completed from the assessment run</i>										
	<i>to be completed from the assessment run</i>										
	<i>to be completed from the assessment run</i>										

L = likelihood, **I** = impact. A row is only added when a tool actually reported it, and its score is agreed by the owner named on the row, not by the script alone.

Priority definitions

Priority	Score	Meaning	Target
P0	20–25	Critical — contain first. An attacker with a standard account is close to controlling the domain	3 days
P1	12–19	High — fix this iteration	14 days
P2	6–11	Medium — planned work	30 days
P3	1–5	Low — backlog, or formally accept	90 days

A finding in the *privileged-access*, *delegation* or *credential-exposure* categories with a score of 12 or more is escalated one band (capped at P0), because handing an attacker direct control of the domain is

urgent even when the raw numbers look borderline.

How each finding is closed

1. **Remediate** and record what changed.
2. **Verify** — `scripts/11-Verify-Remediation.ps1` (or the specific test in the runbook) must show the control in place. Applied is not the same as enforced.
1. **Evidence** — a file in `evidence/public/` named per AGENTS.md 4.5.
2. **Close** the row only when steps 2 and 3 are done.
3. If the business chooses not to fix it, **risk-accept** it: a named owner, a written reason and a review date, below — never a silent closure.

Risk acceptance log

ID	Accepted by (business owner)	Reason	Review date	Recorded

Register summary (to be completed from the assessment run)

Metric	Before	After
PingCastle global risk score	not measured	not measured
PingCastle — Stale Objects	not measured	not measured
PingCastle — Privileged Accounts	not measured	not measured
PingCastle — Trusts	not measured	not measured
PingCastle — Anomalies	not measured	not measured
Purple Knight critical indicators open	not measured	not measured
BloodHound paths from Domain Users to Domain Admins	not measured	not measured
Findings open (P0 / P1 / P2 / P3)	not measured	not measured

Handling rules

- **The raw tool output is never circulated.** The PingCastle HTML, the Purple Knight export and the BloodHound database name the accounts to target and the routes between them. They stay in `evidence/raw/` (git-ignored); this register and sanitized screenshots are what the business sees.
- **No password, hash, key or recovery value appears in this file, ever.**
- The register is reviewed at the monthly privileged-access review; open items and accepted risks are carried forward with their dates.

Honesty note. Halden Distribution Ltd. is a fictional company in an isolated home lab, and the weaknesses this register will list were deliberately seeded so the assessment had something real to find. The measurements will be real; the company is not.

